Questions 1 – 5

Choose the *correct letter*, A, B, C or D.
Write your answer beside each question number on this paper.

1 In its technical sense in IT security, what does the term risk mean?

A The total count of vulnerabilities that remain unpatched inside a system
B The subjective feeling of unease that users experience when a system misbehaves
C The number of countermeasures that are deployed against a class of threat
D The quantitative probability that an error situation occurs and gives rise to damage

2 Which definition of a vulnerability is correct?

A A countermeasure that reduces the frequency of attack attempts
B A weakness that can be exploited in order to damage the system
C A colour code that classifies a threat inside the risk matrix
D A contract that transfers the residual risk to an outside party

3 Objective risk and subjective risk are two distinct notions. Which factor belongs to the subjective definition?

A The level of countermeasures that are applied to protect the asset
B The consequences that follow from a successful attack on the asset
C Human factors such as public attitudes, trust and personality
D The frequency of attempts that exploit a specific vulnerability

4 In IT security, what is synonymous with damage?

A A breach of the security policy defined by the organisation
B A reduction in the performance of the affected computer system
C A financial loss that is recorded in the annual budget of the firm
D A delay in the delivery of services to external paying customers

5 In the basic risk expression $S = F \times K$, what do the symbols F and K represent?

A The financial value of the protected asset and the technical knowledge level of the attacker
B The frequency of attempts to exploit the vulnerability and the consequences of a successful attempt
C The fault rate of the equipment and the length of the cryptographic keys used in encryption
D The frequency of successful attacks and the total number of known vulnerabilities inside the system

Questions 6 – 10

Choose the *correct letter*, A, B, C or D.
Write your answer beside each question number on this paper.

6 A threat is evaluated to give a basic risk S, and countermeasures of level M are applied. Which expression gives the residual risk R?

A The basic risk multiplied by the level of countermeasures
B The basic risk divided by the level of countermeasures
C The basic risk added to the level of countermeasures
D The basic risk reduced by the number of countermeasures

7 A threat is placed in the red area of the risk matrix. What does that position indicate?

A The consequences are high while the frequency of attempts stays low
B Both the frequency of attempts and the consequences are low for this threat
C The consequences are low while the frequency of attempts stays high
D Both the frequency of attempts and the consequences are high for this threat

8 An organisation wants to block attacks that arrive from the internet. Which countermeasure is appropriate?

A Place the equipment inside a secure room with restricted physical access
B Take regular backup copies of the data and software held on the systems
C Deploy firewalls in the network to stop hostile traffic from reaching the target
D Deploy antivirus programs that scan files for known malicious code on hosts

9 A storm damages the roof above a data centre and water reaches the servers. Into which threat group does this event fall?

A Liveware related threats that come from human error among users
B Software related threats that affect the installed applications
C Hardware related threats that physically affect the computer equipment
D Data related threats that lead to unauthorised data processing

10 Forbidding risky behaviour such as the use of WiFi is one way of handling risk. Which mitigation strategy does that example illustrate?

A Risk avoidance, since the target system is kept away from the risk
B Risk transfer, since the risk is handed over to an outside party
C Risk retention, since a small agreed residual risk is accepted
D Risk reduction, since proactive steps are taken to limit future losses

Questions 11 – 15

Choose the *correct letter*, A, B, C or D.
Write your answer beside each question number on this paper.

11 Threats to an IT system are commonly grouped into four families instead of treating intrusion as the only threat. Which statement best explains why?

A Physical surroundings affect hardware alone and never influence the data layer at all
B Threats also arise from physical surroundings, software faults, data misuse and human error
C Intrusion belongs to the liveware family because a human being performs the attack
D Attackers are rare in practice, so the remaining families describe accidental events only

12 Inference is classified as a data related threat. What does inference mean in that context?

A Deleting confidential records from a database without authorisation
B Copying licensed software between machines without a valid licence
C Deducing confidential information from data that is legitimately accessible
D Pretending to be another user in order to obtain access rights

13 An organisation documents a low-probability threat, reserves budget for it and continues operations without further action. Which mitigation strategy does this behaviour implement?

A Risk sharing, since several parties agree to handle the risk jointly
B Risk retention, since a certain agreed amount of residual risk is accepted
C Risk transfer, since the risk is moved to an external contract partner
D Risk reduction, since proactive steps are taken to prevent future loss

14 Several physical access-control technologies are used at building entrances. Which statement correctly describes a smart card?

A It uses radio signals to identify tags from a distance without any contact
B Its magnetic stripe stores coded spots that any stripe reader can copy
C It relies on a personal access code that is typed on a keypad at the door
D Its intelligent circuitry hides user data until the authentication process succeeds

15 Several systematic security analysis frameworks are in use. Which description matches ISO/IEC 27002?

A An evaluation process for the threats, assets and vulnerabilities of a firm
B A taxonomy of the factors that can contribute to the formation of risk
C A checklist of the things that must be considered to achieve a secure system
D A description of the internal processes that a company has to follow

Questions 16 – 20

Choose the *correct letter*, A, B, C or D.
Write your answer beside each question number on this paper.

16 Risk management is often organised as a PDCA process. Which activity belongs to the Check phase?

A Monitoring the implemented solution to confirm that the security level is maintained
B Identifying the threats, analysing the risks and planning the countermeasures
C Implementing the countermeasures and the related risk management activities
D Adjusting the solution or deciding to start a completely new cycle of work

17 Two departments apply the same number of countermeasures against one threat, yet their residual risks differ. Which explanation accounts for this?

A Residual risk never changes once the number of countermeasures has been fixed
B Only the frequency of attempts can change the residual risk of a threat
C Only the consequence value can change the residual risk of a threat
D Effectiveness differs between controls, and M reflects effectiveness as well as count

18 A clinic cannot afford full redundancy but must keep patient data recoverable. Which pair of strategies fits both constraints best?

A Reduction through backups and encryption, with retention of the remaining risk
B Sharing of the risk with regulators, with no additional technical measures
C Avoidance of all digital records, with transfer of the risk to an insurer only
D Transfer of every risk to an outsourcer, with no internal controls retained

19 A cohesive access-control policy is recommended at every level of an organisation. Which argument best supports that recommendation?

A Free internal movement makes it hard to protect assets and to prevent accidents
B Visitors are the only group that is able to bypass the physical security perimeter
C Access-control devices are cheaper when the policy covers a single level only
D Employees never misuse the assets that they are authorised to reach at work

20 A facility must verify identity by combining knowledge, possession and inheritance factors. Which configuration satisfies that requirement?

A A smart card, an identity badge and a magnetic stripe card used together
B A fingerprint scan, an iris scan and a voice recognition check used together
C A password, a personal identification number and a second secret password
D A password, a smart card and a fingerprint scan used together at the entry point

Answer key

1	D	6	B	11	B	16	A
2	B	7	D	12	C	17	D
3	C	8	C	13	B	18	A
4	A	9	C	14	D	19	A
5	B	10	A	15	C	20	D